

mysql加固

笔记本：应用服务加固

创建时间：2018/11/2 21:23

更新时间：2018/11/3 20:13

作者：苏醒

URL：suxing

数据库管理人员可以参考本文档进行 MySQL 数据库系统的安全配置加固，提高数据库的安全性，确保数据库服务稳定、安全、可靠地运行。

安全加固

1、修改端口

使用命令show global variables like 'port';查看端口号

```
mysql> show global variables like 'port';
```

```
+-----+-----+  
| Variable_name | Value |  
+-----+-----+  
| port | 3306 |  
+-----+-----+
```

1 row in set (0.00 sec)

修改端口，编辑/etc/my.cnf文件

```
[mysqld]
```

```
port=3307
```

```
datadir=/var/lib/mysql
```

```
socket=/var/lib/mysql/mysql.sock
```

```
user=mysql
```

```
# Disabling symbolic-links is recommended to prevent assorted security risks
```

```
symbolic-links=0
```

```
/etc/init.d/mysql restart
```

查看效果：

```
mysql> show global variables like 'port';
```

```
+-----+-----+  
| Variable_name | Value |  
+-----+-----+  
| port | 3307 |  
+-----+-----+
```

1 row in set (0.00 sec)

2、禁止 Mysql 以管理员帐号权限运行

以普通帐户安全运行 mysqld，禁止以管理员帐号权限运行 MySQL 服务。在 /etc/my.cnf 配置文件中进行以下设置。

1. **[mysql.server]**

2. **user=mysql**

3、避免不同用户间共享帐号（不同数据库不同）

创建用户。

```
insert into mysql.user(Host,User>Password) values("localhost","test",password("1234"));
```

这样就创建了一个名为：test 密码为：1234 的用户。注意：此处的"localhost"，是指该用户只能在本机登录，不能在另外一台机器上远程登录。如果想远程登录的话，将"localhost"改为"%"，表示在任何一台电脑上都可以登录。也可以指定某台机器可以远程登录。

4、删除无关用户

DROP USER 语句可用于删除一个或多个 MySQL 账户。使用 DROP USER 命令时，必须确保当前账号拥有 MySQL 数据库的全局 CREATE USER 权限或 DELETE 权限。账户名称的用户和主机部分分别与用户表记录的 User 和 Host 列值相对应。

执行 **DROP USER user;** 语句，您可以取消一个账户和其权限，并删除来自所有授权表的帐户权限记录。

- a. @>mysql -u root -p
- b. mysql>Delete FROM user Where User='test' and Host='localhost';
- c. mysql>flush privileges;
- d. mysql>drop database testDB; //删除用户的数据库
- e. 删除账户及权限：>drop user 用户名@'%';
- f. >drop user 用户名@ localhost;

g. 5修改指定用户密码

- h. @>mysql -u root -p
- i.
- j. mysql>update mysql.user set password=password('新密码') where User="test" and Host="localhost";
- k. mysql>flush privileges;

6、口令安全

检查账户默认密码和弱密码。口令长度需要至少八位，并包括数字、小写字母、大写字母和特殊符号四类中的至少两种类型，且五次以内不得设置相同的口令。密码应至少每 90 天进行一次更换。

您可以通过执行以下命令修改密码。

- 1. mysql> update user set password=password('test!p3') where user='root';
- 2. mysql> flush privileges;

7、授权--分配用户最小权限

在数据库权限配置能力范围内，根据用户的业务需要，配置其所需的最小权限。

- i. 查看数据库授权情况。

- 1. mysql> use mysql;

```
2. mysql> select * from user;
3. mysql> select * from db;
4. mysql> select * from host;
5. mysql> select * from tables_priv;
6. mysql> select * from columns_priv;
```

ii. 通过 revoke 命令回收不必要的或危险的授权。

```
1. mysql> help revoke
2. Name: 'REVOKE'
3. Description:
4. Syntax:
5. REVOKE
6. priv_type [(column_list)]
7. [, priv_type [(column_list)]] ...
8. ON [object_type]
9. {
10. *
11. | *.*
12. | db_name.*
13. | db_name.tbl_name
14. | tbl_name
15. | db_name.routine_name
16. }
17. FROM user [, user] ...
```

8、开启日志审计功能

数据库应配置日志功能，便于记录运行状况和操作行为。

MySQL服务有以下几种日志类型：

错误日志：-log-err

查询日志：-log（可选）

慢查询日志：-log-slow-queries（可选）

更新日志：-log-update

二进制日志：-log-bin

找到 MySQL 的安装目录，在 my.ini 配置文件中增加上述所需的日志类型参数，保存配置文件后，重启 MySQL 服务即可启用日志功能。例如，

1. **#Enter a name for the binary log. Otherwise a default name will be used.**
2. **#log-bin=**
3. **#Enter a name for the query log file. Otherwise a default name will be used.**
4. **#log=**
5. **#Enter a name for the error log file. Otherwise a default name will be used.**
6. **log-error=**
7. **#Enter a name for the update log file. Otherwise a default name will be used.**
8. **#log-update=**

该参数中启用错误日志。如果您需要启用其他的日志，只需把对应参数前面的“#”删除即可。

日志查询操作说明

执行 `show variables like 'log_%';` 命令可查看所有的 log。

执行 `show variables like 'log_bin';` 命令可查看具体的 log。

<http://www.cnblogs.com/kerrycode/p/7130403.html>

如果不需要，应禁止远程访问

关闭远程访问:

```
use mysql;
```

```
update user set host = "localhost" where user = "root" and host= "%";
```

```
flush privileges;
```

连接数设置

根据您的机器性能和业务需求，设置最大、最小连接数。

在 MySQL 配置文件（my.conf 或 my.ini）的 [mysqld] 配置段中添加 `max_connections = 1000`，保存配置文件，重启 MySQL 服务后即可生效。

基础知识：

1. 5. 列出所有数据库

```
2. mysql>show database;
```

3. 6. 切换数据库

```
4. mysql>use '数据库名';
```

5. 7. 列出所有表

6. mysql>show tables;

7. **8. 显示数据表结构**

8. mysql>describe 表名

9. **9. 删除数据库和数据表**

10. mysql>drop database 数据库名;

11. mysql>drop table 数据表名;